IS Audit & Control

Abdul-Rahman Mahmood

Assistant Professor, Computer Science, FAST-NU

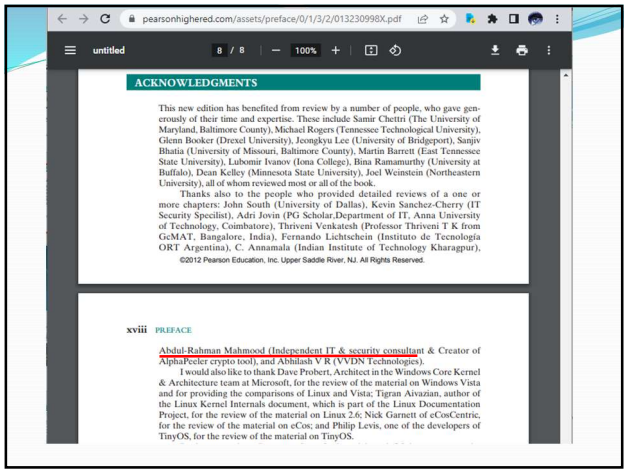
abdulrahman@nu.edu.pk
alphapeeler.sf.net/pubkeys/pkey.htm
pk.linkedin.com/in/armahmood
bqb-tsid-asp
alphapeeler
alphapeeler
armahmood786
http://alphapeeler.sf.net/
reddit.com/user/alphapeeler
www.flickr.com/alphapeeler
http://alphapeeler.tumblr.com
armahmood786@jabber.org
alphapeeler@aim.com
abdulmahmood-sss
alphapeeler@icloud.com
pinterest.com/alphapeeler

About The Instructor

https://alphapeeler.sourceforge.net/index4stu.html#about
https://pk.linkedin.com/in/armahmood

Student Life Achievements

- **Operating Systems book**
- https://alphapeeler.sourceforge.net/index4stu.html#achievements_os
- **CEHv12 Mod020 – Cryptanalysis**
- https://alphapeeler.sourceforge.net/index4stu.html#achievements_cryptana
- **AlphaPeeler Credited by other YouTubers**
- https://alphapeeler.sourceforge.net/index4stu.html#achievements_yt
- **Referred in Certified Ethical Hacking manuals**
- **https://alphapeeler.sourceforge.net/index4stu.html#achievements_ceh**
- **Books and articles references**
- https://alphapeeler.sourceforge.net/index4stu.html#achievements_books_articles



pearsonhighered.com/assets/preface/0/1/3/2/013230998X.pdf

untitled 8 / 8 100%

ACKNOWLEDGMENTS

This new edition has benefited from review by a number of people, who gave generously of their time and expertise. These include Samir Chettri (The University of Maryland, Baltimore County), Michael Rogers (Tennessee Technological University), Glenn Booker (Drexel University), Jeongkyu Lee (University of Bridgeport), Sanjiv Bhatia (University of Missouri, Baltimore County), Martin Barrett (East Tennessee State University), Lubomir Ivanov (Iona College), Bina Ramamurthy (University at Buffalo), Dean Kelley (Minnesota State University), Joel Weinstein (Northeastern University), all of whom reviewed most or all of the book.

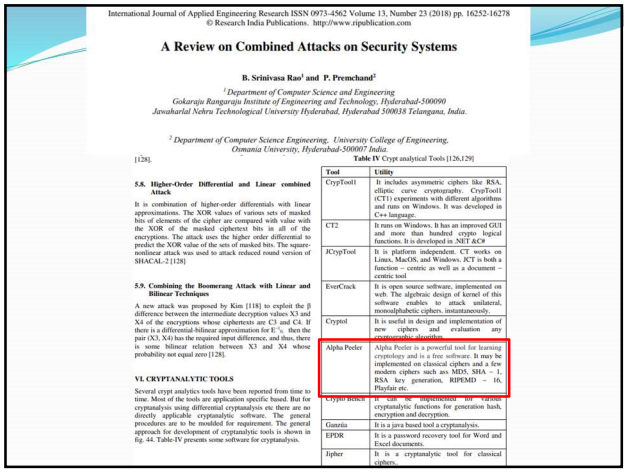
Thanks also to the people who provided detailed reviews of a one or more chapters: John South (University of Dallas), Kevin Sanchez-Cherry (IT Security Specilist), Adri Jovin (PG Scholar,Department of IT, Anna University of Technology, Coimbatore), Thriveni Venkatesh (Professor Thriveni T K from GcMAT, Bangalore, India), Fernando Lichtschein (Instituto de Tecnología ORT Argentina), C. Annamala (Indian Institute of Technology Kharagpur),

©2012 Pearson Education, Inc. Upper Saddle River, NJ. All Rights Reserved.

xviii PREFACE

Abdul-Rahman Mahmood (Independent IT & security consultant & Creator of AlphaPeeler crypto tool), and Abhilash V R (VVDN Technologies).

I would also like to thank Dave Probert, Architect in the Windows Core Kernel & Architecture team at Microsoft, for the review of the material on Windows Vista and for providing the comparisons of Linux and Vista; Tigran Aivazian, author of the Linux Kernel Internals document, which is part of the Linux Documentation Project, for the review of the material on Linux 2.6; Nick Garnett of eCosCentric, for the review of the material on eCos; and Philip Levis, one of the developers of TinyOS, for the review of the material on TinyOS.



International Journal of Applied Engineering Research ISSN 0973-4562 Volume 13, Number 23 (2018) pp. 16252-16278
© Research India Publications. http://www.ripublication.com

A Review on Combined Attacks on Security Systems

B. Srinivasa Rao[1] and P. Premchand[2]

[1] *Department of Computer Science and Engineering Gokaraju Rangaraju Institute of Engineering and Technology, Hyderabad-500090 Jawaharlal Nehru Technological University Hyderabad, Hyderabad 500038 Telangana, India.*

[2] *Department of Computer Science Engineering, University College of Engineering, Osmania University, Hyderabad-500007 India.*

[128].

5.8. Higher-Order Differential and Linear combined Attack

It is combination of higher-order differentials with linear approximations. The XOR values of various sets of masked bits of elements of the cipher are compared with value with the XOR of the masked ciphertext bits in all of the encryptions. The attack uses the higher order differential to predict the XOR value of the sets of masked bits. The square-nonlinear attack was used to attack reduced round version of SHACAL-2 [128]

5.9. Combining the Boomerang Attack with Linear and Bilinear Techniques

A new attack was proposed by Kim [118] to exploit the β difference between the intermediate decryption values X3 and X4 of the encryptions whose ciphertexts are C3 and C4. If there is a differential-bilinear approximation for E⁻¹ₖ then the pair (X3, X4) has the required input difference, and thus, there is some bilinear relation between X3 and X4 whose probability not equal zero [128].

VI. CRYPTANALYTIC TOOLS

Several crypt analytics tools have been reported from time to time. Most of the tools are application specific based. But for cryptanalysis using differential cryptanalysis etc there are no directly applicable cryptanalytic software. The general procedures are to be moulded for requirement. The general approach for development of cryptanalytic tools is shown in fig. 44. Table-IV presents some software for cryptanalysis.

Table IV Crypt analytical Tools [126,129]

Tool	Utility
CrypTool1	It includes asymmetric ciphers like RSA, elliptic curve cryptography. CrypTool1 (CT1) experiments with different algorithms and runs on Windows. It was developed in C++ language.
CT2	It runs on Windows. It has an improved GUI and more than hundred crypto logical functions. It is developed in .NET &C#
JCrypTool	It is platform independent. CT works on Linux, MacOS, and Windows. JCT is both a function – centric as well as a document – centric tool
EverCrack	It is open source software, implemented on web. The algebraic design of kernel of this software enables to attack unilateral, monoalphabetic ciphers, instantaneously.
Cryptol	It is useful in design and implementation of new ciphers and evaluation any cryptographic algorithm.
Alpha Peeler	Alpha Peeler is a powerful tool for learning cryptology and is a free software. It may be implemented on classical ciphers and a few modern ciphers such ass MD5, SHA – 1, RSA key generation, RIPEMD – 16, Playfair etc.
Crypto Bench	It can be implemented for various cryptanalytic functions for generation hash, encryption and decryption.
Ganzúa	It is a java based tool a cryptanalysis.
EPDR	It is a password recovery tool for Word and Excel documents.
Jipher	It is a cryptanalytic tool for classical ciphers.



Ethical Hacking and Countermeasures Cryptography — Exam 312-50 Certified Ethical Hacker

Cryptanalysis Tools

CEH

CryptoBench http://www.addario.org
AlphaPeeler http://alphapeeler.sourceforge.net
JCrypTool http://www.cryptool.org
Draft Crypto Analyzer http://www.literatecode.com
Ganzúa http://ganzua.sourceforge.net
Linear Hull Cryptanalysis of PRESENT http://www.crypt.eu.org
Crank http://crank.sourceforge.net
mediggo http://code.google.com
EverCrack http://evercrack.sourceforge.net
SubCypher http://www.esclepiusllc.com

Copyright © by EC-Council All Rights Reserved. Reproduction is Strictly Prohibited.

Cryptanalysis Tools

In addition to CrypTool, many tools that allow you to perform cryptanalysis are available:

- CryptoBench available at http://www.addario.org
- JCrypTool available at http://www.cryptool.org
- Ganzúa available at http://ganzua.sourceforge.net
- Crank available at http://crank.sourceforge.net
- EverCrack available at http://evercrack.sourceforge.net
- AlphaPeeler available at http://alphapeeler.sourceforge.net

https://www.taylorfrancis.com/chapters/edit/10.1201/9781003508632-6/cryptanalysis-using-cryptool-alphapeeler-bishwajeet-pandey-keshav-kumar-pushpanjali-pandey-bakar



Chapter

Cryptanalysis using CrypTool and AlphaPeeler

By Bishwajeet Pandey, Keshav Kumar, Pushpanjali Pandey, W. A. W. A. Bakar

Book Next Generation Mechanisms for Data Encryption

Edition	1st Edition
First Published	2025
Imprint	CRC Press
Pages	8
eBook ISBN	9781003508632

About The Course

Class Policies

- Attendance : 80% is required.
- Remaining 20% : sick leave, emergencies.
- Cross Section Attendance is not allowed
  Late Assignment Submission till after 1 week of actual deadline. (Marks deduction applies for late submission)
- After 1 week submissions of assignment won't be accepted.
- All Submissions on Google forms, no email submission
- Plagiarism will not be tolerated.
- Class Exit SOP : wait for me to exit you.
- Q&A session : Last 5-7 minutes of each lecture.
- For further discussions, refer consultation schedule: https://calendar.google.com/calendar/u/1?cid=YWJkdWxyYWhtYW5AbnUuZWR1LnBr

Reference books

- IT Auditing: Using Controls to Protect Information Assets, 2nd Edition by Chris Davis, Mike Schiller with Kevin Wheeler.
- Auditing Information Systems, Second Edition by Jack J. Champlain.
- Information System Control and Audit by Ron Weber
- CISA Review Manual 2010

Assessment

- The course material builds your innovation skills cumulatively
- Spot tests will be given periodically to assess your comprehension of the readings.
- Class participation is graded based on student participation in practicum exercises.
- There will be midterm and final examinations that are cumulative.

Midterm	30%
Assignment	10%
Final Exam	50%
Project	10%
Total	100%

GCR codes (Section as on flex)

- Section A: **fpmpz26**
- Section B: **moqtiwa**

Course Catalogue - HEC

- **Course Outline:**
- IS Audit charter, Polices, Procedures, Audit computer networks and communication, Auditing software development, Acquisition, Maintenance, Auditing IT infrastructure, Auditing Management and Organization, Business process re-engineering: IS audit proposal, report, evidence and follow-up, complaint to standard, Enterprise service agreement, Backup and procedures

Course Goals

- After successful completion of this course students should be able to do auditing of information systems.
- Develop and implement a risk-based IS audit strategy in compliance with IT Audit Standards, to ensure that key areas are included.
- Plan specific audits to determine whether information systems are protected, controlled and provided value to the organization.

Course Goals

- Conduct audits in accordance with IT audit standards to achieve planned audit objectives.
- Report audit findings and make recommendations to key stakeholders to communicate results and effect change when necessary.
- Conduct follow-ups or prepare status reports to ensure that appropriate actions have been taken by management in a timely manner.

Introduction to Information System Audit

Auditing

- An **audit** is an evaluation of an organization, system, process, project or product.
  - performed by a competent, independent, objective, and unbiased person or persons, known as **auditors**.
- **Purpose**
  - Make an **independent assessment** based on management's representation of their financial condition (through their financial statements).
  - To ensure the **operating effectiveness** of the internal accounting system is in accordance with approved and accepted accounting standards / practices.
  - Evaluates the **internal controls** to determine if conformance will continue, and recommends necessary changes in policies, procedures or controls.
- Auditing is a part of quality control certifications such as ISO 9000.

Financial Audit

- Is an ***assurance* or *attestation*** on *financial statements* provided by accounting firms, whereby the firm provides an *independent opinion* on *published* information.
- Performed by firms of *practicing accountants* due to the financial reporting knowledge they require.
- **Internal auditors**, do not attest to financial reports but focus mainly on the internal controls of the organization.
- External auditors
  - US's Certified Public Accountant (CPA)
  - UK's Chartered Certified Accountant (ACCA) and Chartered Accountants
  - (A.F. Ferguson & Co. , KPMG Taseer Hadi & Co. , *Moody International*)

History

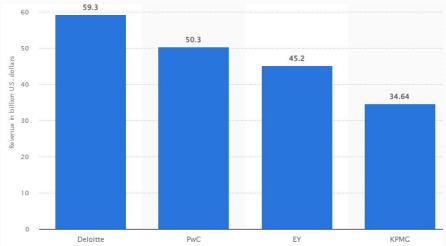
- Independent auditing developed with the expansion of the British Empire in the 19th century
- **Prior to the 1930s**, corporations were required neither to submit annual reports to government agencies or shareholders nor to have such reports audited.
  - The **1929 boom** initiated to pressure for audit of publicly traded companies;
  - In the **UK, the London Association of Accountants** successfully **campaigns** for the right to audit companies in 1930
  - In the **US, the Securities Exchange Act of 1934** required all publicly traded companies to disclose certain financial information, and that financial information be audited.
  - The establishment of the **U.S. Securities and Exchange Commission (SEC)** created a **body to enforce the audit** requirements.
  - Securities and Exchange Commission of Pakistan (1999)

History since 1980

- The Pro-business **Reagan administration** in the US, and the **Thatcher regime** in the UK **lifted** many of the controls over the profession
  - Leading to abuses that resulted in the crashes of 1987 and 2001
- Since then, the Sarbanes-Oxley Act (SOX) has forced an expansion of audit responsibility and driven up audit revenues (and costs)
- One study estimated the net private cost of SOX to amount to $1.4 trillion in the US.
  - It is an econometric estimate of "the loss in total market value around the most significant legislative events"—i.e., the costs minus the benefits as perceived by the stock market as the new rules were enacted.

Audit Firms

- **The largest accounting firms (the** 'Big 4' or 'Final 4') audit nearly all of large quoted/listed companies.
- In addition to providing audits, they also provide other services including tax advice and strategic consultancy
- The 5th largest firm, Grant Thornton, has only around 10% of the revenues of KPMG

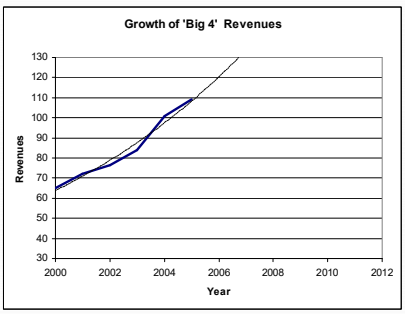


https://www.statista.com/statistics/250479/big-four-accounting-firms-global-revenue/

Worldwide Big 4 revenues

- The revenues of the big accounting firms grew by a healthy **15%** last year.
- They are in effect, the back office of the global markets
- They are a "private **police force**... hired, fired and paid for by company management"
- The "big four" firms employ around **half a million** people

Worldwide Big 4 revenues



Stages of an audit

- **Planning and risk assessment.**
- **Internal controls testing.**
- **Substantive procedures**

Planning and risk assessment

- Timing: before year-end
- Purpose:
  - to understand the business of the company and the environment in which it operates.
  - to determine the major audit risks (i.e. the chance that the auditor will issue the wrong opinion).
- For example, if sales representatives stand to gain bonuses based on their sales, and they account for the sales they generate, they have both the incentive and the ability to overstate their sales figures, thus leading to overstated revenue.
  - In response, the auditor would typically plan to increase the precision of their procedures for checking the sales figures.

Stages of an audit

Internal controls testing

- Timing: before year-end
- Purpose: to assess the internal control procedures
  - (e.g. by checking computer security, account reconciliations, segregation of duties). If internal controls are assessed as strong, this will reduce (but not entirely eliminate) the amount of 'substantive' work the auditor needs to do

Definitions

- Balance Sheet : A financial statement that summarizes a company's assets, liabilities and shareholders' equity at a specific point in time. These three balance sheet segments give investors an idea as to what the company owns and owes, as well as the amount invested by shareholders.
- The balance sheet adheres to the following formula:
- Assets = Liabilities + Shareholders' Equity

Definitions

- In accounting and finance, **equity** is the difference between the value of the assets/interest and the cost of the liabilities of something owned. For example, if someone owns a car worth $15,000 but owes $5,000 on that car, the car represents $10,000 **equity**.

Definitions

- In financial accounting, a **cash flow statement**, also known as **statement** of **cash flows**, is a financial **statement** that shows how changes in balance sheet accounts and income affect **cash** and **cash** equivalents, and breaks the analysis down to operating, investing and financing activities.

Substantive procedures

- **Timing:** after year-end
- **Purpose:** to check that the actual numbers in the Income Statement and Balance Sheet (and, where applicable, Statement of Changes in Equity and Cash Flow Statement) are reliable, by performing tests that use the numbers provided.
- **Methods:**
  - where internal controls are strong, auditors typically rely more on **Substantive Analytical Procedures** (the comparison of sets of financial information, and financial with non-financial information, to see if the numbers 'make sense' and that unexpected movements can be explained)
  - where internal controls are weak, auditors typically rely more on **Substantive Tests of Detail** (selecting a sample of items from the major account balances, and finding hard evidence (e.g. invoices, bank statements) for those items

Audit Report Card

- In 2005, 174 auditors were inspected by the Public Company Accounting Oversight Board (PCAOB)
  - almost half have been deemed to have some trouble doing their job satisfactorily.
- On January 19th 2006, Grant Thornton became the latest.
  - Fifteen of its audits were found to have significant "deficiencies" and one client had to restate at least part of its financial statements as a result of the inspection.
- Some audits by the "Big Four" accounting firms have also been found wanting (A few clients of each of the four restated their accounts)
  - At least 19 of PwC's audits, for instance, were found to include deficiencies.

- ***Most of these failures resulted from accounting firms' inability to properly audit computer based accounting systems***

New Business Models

- The business of providing high-end temporary accounting help is already worth $5 billion a year
- Siegfried Group has seen Revenues **sextuple** in the past two years, to $73m.
- In 2003 its core accounting business had just 15 clients; last year it had 100; by the end of May it had 155.
- More than 50 of these are among America's largest companies.
- Siegfried has even received business from a Big Four accounting firm.
- Siegfried's astonishing growth is explained by what it does not do: consulting and auditing, the signature products of the big firms.
- Siegfried is on the other side of the outsourcing boom: it is an insourcer.

What are Information Systems? (and why do auditors care?)





The Information Tech Industry

- IT now represents 60% of expenditure in Fortune 500 companies
  - 90% in Finance companies
  - Over $4 trillion annual expenditure (broadly defined)
- Most of this is financial record keeping

How did we get here?

Automated Clerks: **1963-1980**

- **Back Office**
- Computers as automated accountants
- Goals were efficiency and cost control
- "Legacy" systems automated manual tasks
- … but had no significant effect on management's decision making



How did we get here?

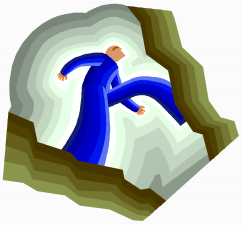
Empowerment: 1980-1995

- **Client / server** systems enhanced the productivity of knowledge workers
- Word processing, spreadsheets, and other tools
- Fomented a "white-collar" revolution



How did we get here?
Networking: 1995 onward

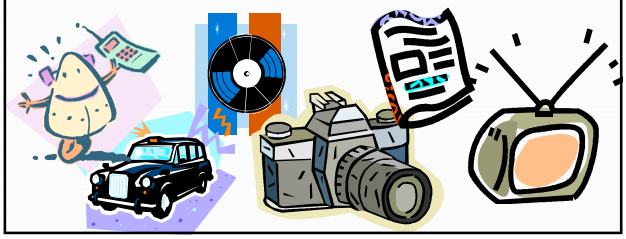
- The **Virtual Office** (Global Marketplace)
- Net and Web and internal networks integrate the separate activities of the firm
- What were "islands of data" have become "knowledge nodes" accessible to the whole firm
- … and the global marketplace



How did we get here?
Embedding: **2002-2010**



- Computers grow cheap, small and powerful
- Morphing into a commodity platform
- Which substitutes for all sorts of devices



How did we get here?
Invisibility: c. 2020



The "The Web" becomes
- an all-pervasive info presence,
- Devices plug in and rewire on the fly
- "Smart dust" monitors everything

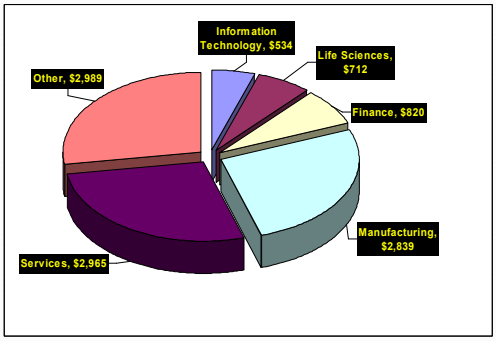
- *The Rest?:* Machines taking care of the work

Where are we ?
Industry Structure, c. 2006

Information Technology Market	Annual Expenditures ($US billion)	Employees (thousand)	Major Suppliers
Operations & Accounting	500	2000	US, India
Search & Storage	1000	5000	US
Tools	300	300	US, Germany
Embedded	1500	700	US, Japan, Korea, Greater China
Communications	700	2000	US, Germany, Japan, Greater China
Total	**4,000**	**10,000**	GWP ~$45 trillion (Pop: 6 billion) US GDP ~$10 trillion (Pop: 300 million)

* Gross domestic product (GDP)
* The gross world product (GWP)

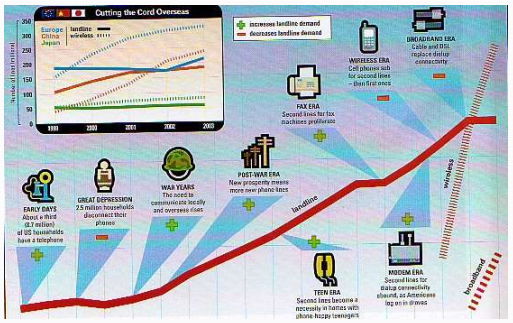
Where's the Money?
U.S. Output: Contribution to GDP (in billions)



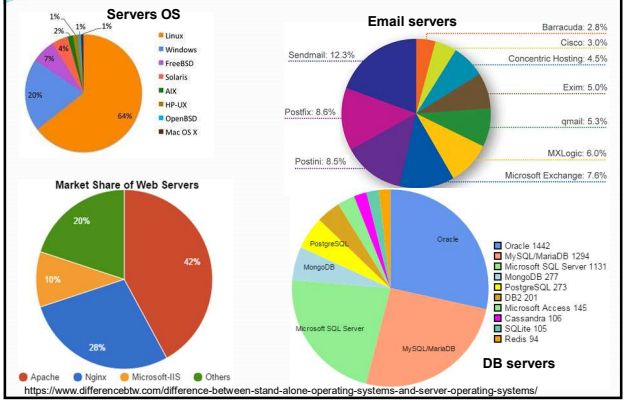
Operations & Accounting



Networks

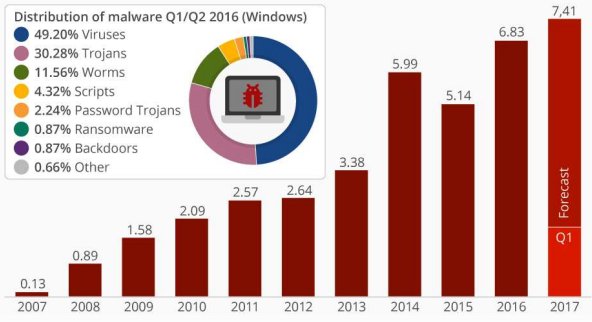


Market Share of servers 2017



https://www.differencebtw.com/difference-between-stand-alone-operating-systems-and-server-operating-systems/

Problems: Malware and Spam 2016

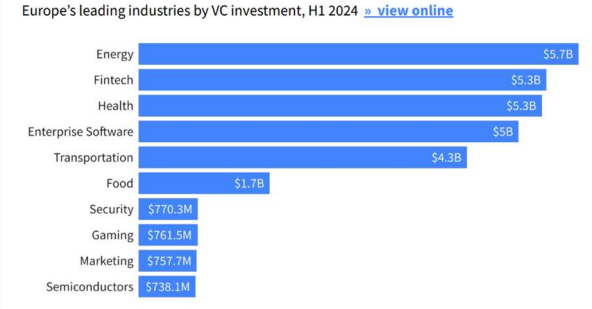


https://www.statista.com/chart/10045/new-malware-specimen-and-share-of-windows-based-malware/

IT Industry Leaders

THE BIGGEST		THE FASTEST GROWING		THE MOST PROFITABLE		THE BEST RETURNS	
COMPANY	CURRENT SALES (MILLIONS)	COMPANY	REVENUE GROWTH	COMPANY	RETURN ON EQUITY	COMPANY	SHAREHOLDER RETURN THROUGH 5/30/04
IBM	$91,316.0	LEXAR MEDIA	161.4%	MEDIATEK	55.2%	TELESYSTEM INT. WIRELESS	264.7%
HEWLETT-PACKARD	76,828.0	QUANTA COMPUTER	108.8	ACCENTURE	47.2	AU OPTRONICS	264.6
SAMSUNG ELEC.	54,464.2	SANDISK	107.4	DELL	45.5	YAHOO! JAPAN	215.1
NTT DOCOMO	48,455.2	YAHOO!	100.3	NII HOLDINGS	41.5	CHI MEI OPTOELECTRONICS	215.1
NEC	47,099.5	UTSTARCOM	99.9	YAHOO! JAPAN	41.5	NII HOLDINGS	202.1
FUJITSU	45,137.1	MOBILE TELESYSTEMS	87.0	UNIV. OF PHOENIX ONLINE	40.2	SOFTBANK	194.6
DELL	43,452.0	CHINA UNICOM	78.3	NOVATEK MICROELEC.	39.1	AUTODESK	141.4
MICROSOFT	35,608.0	ADVANTEST	78.2	TELEFONICA MOVILES	37.2	MOTOROLA	135.0
TELEFONICA	35,511.5	VIMPEL-COMMUNICATIONS	73.8	ORACLE	34.4	WIPRO	130.8
INTEL	31,481.0	ASUSTEK COMPUTER	71.6	SK TELECOM	34.4	MOBILE TELESYSTEMS	126.8

Europe's Venture Capital Industries 2024



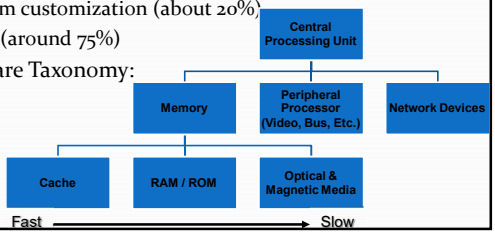
https://seedblink.com/2024-08-01-state-of-fundraising-in-q2-2024-key-findings-from-market-reports

IS Components

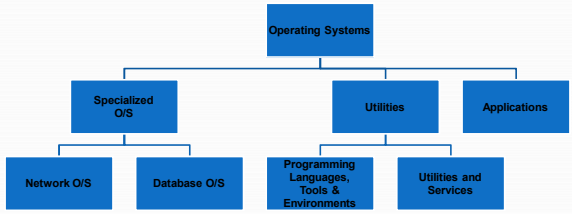
Hardware & Software

Software & Hardware

- Until the 1950s, there was no differentiation between the two
- By the turn of the 21st century, they had both been commoditized
- Most of the money in IT now goes into:
  - System customization (about 20%)
  - Data (around 75%)
- Hardware Taxonomy:



Software Taxonomy

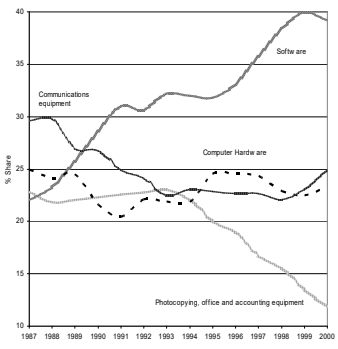


Programming

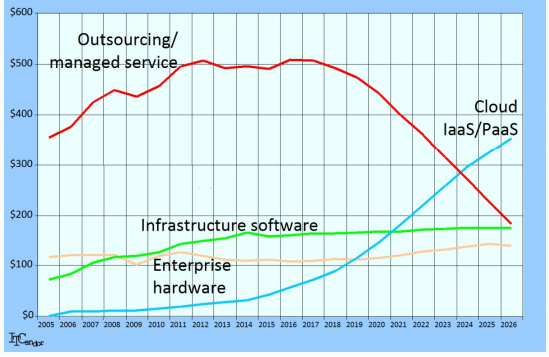
- Basically the **core task** in Information System
- Languages:
  - Translate from human language (task specific)
  - To machine language (bits & bytes)
  - And back to human language
- Today, these are **just one part** of a
  - Development environment
  - That keeps track of numerous design decisions.
- What Machines do Well
  - High **speed** arithmetic
  - **Massive** storage and search
  - **Repetitive**, structured processes
  - Consequently they often have difficulty with many real world tasks

Applications Software Rules(1967:2000)

- Proportion of total IT industry revenues
- 1967-2000

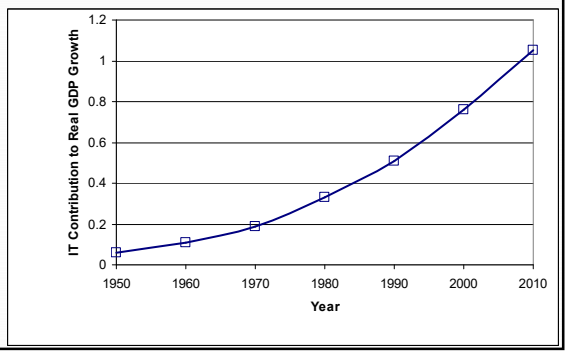


World enterprise computing forecast ($b) by area – 2005-2020



http://www.itcandor.com/cloud-forecast-q217/

IT's Contribution to US GDP Growth



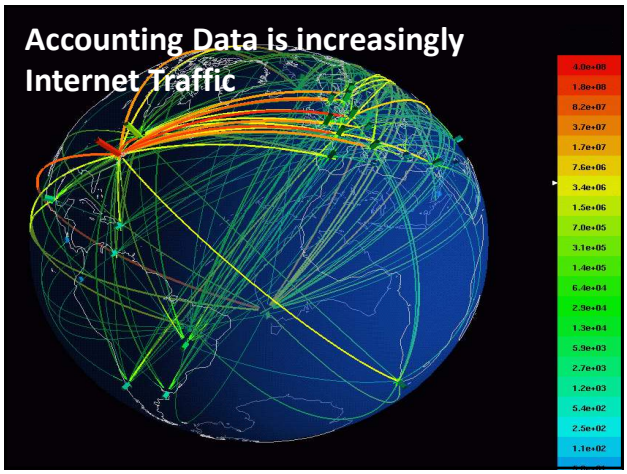
How does IS change accounting?



- **They have shifted**
  - **away from the economics of shortage and resource allocation,**
- **Towards an economics of increasing returns**
  - **information, attention and coordination**



Accounting Data is increasingly Internet Traffic



Where IS and Audit Meet



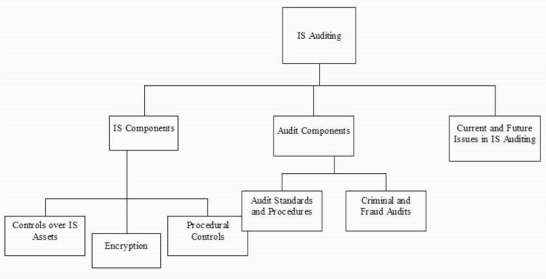
What Auditors Need to Know about IS

1. IS Security
2. Utility Computing and IS Service Organizations
3. Physical Security
4. Logical Security
5. IS Operations
6. Controls Assessment
7. Encryption and Cryptography
8. Computer Forensics
9. New Challenges from the Internet: Privacy, Piracy, Viruses and so forth
10. Auditing and Future Technologies (RFID, Full Automation of Substantive and Control Tests)

Future Opportunities

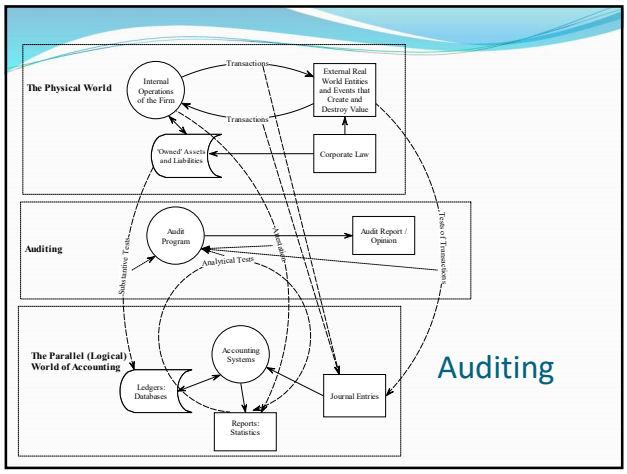
- Automated / Robot Auditors
  - Technologies:
    - Scanning,
    - Surveillance,
    - Logging and Analysis,
    - Forensics
  - Advantages:
    - Always 'on'
    - Sample sizes large enough for reliability
    - No system 'learning curve'; shared experience database
    - Objective, Not biased / unfavorable assessment

Organization of IS Audit study

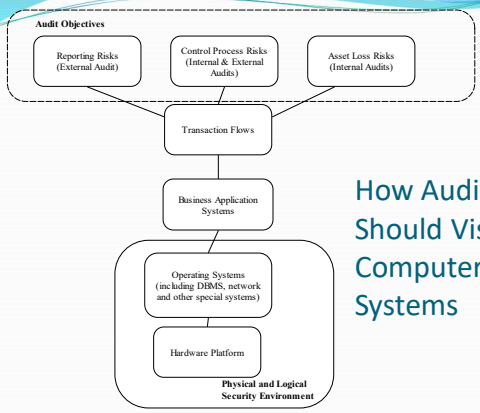


IS Audit Programs

What is IS Auditing?
Why is it Important?
What is the Industry Structure?
Attestation and Assurance



Auditing



How Auditors Should Visualize Computer Systems

The IS Auditor's Challenge

- Corporate Accounting is in a constant state of flux
  - Because of advances in Information Technology applied to Accounting
    - Information that is needed for an Audit is often hidden from easy access by auditors
    - Making computer knowledge an important prerequisite for auditing
- IS (and also just Information) assets are increasingly the main proportion of wealth held by corporations

The Challenge to Auditing Presented by Computers

- Transaction flows are less visible
  - Fraud is easier
  - Computers do exactly what you tell them
    - ***To err is human***
    - ***But, to really screw up you need a computer***
- Audit samples require computer knowledge and access
- Transaction flows are much larger (good for the company, bad for the auditor)
  - Audits grow bigger and bigger from year to year
    - And there is more pressure to eat hours
- Environmental, physical and logical security problems grow exponentially
  - Externally originated viruses and hacking
  - are the major source of risk
    - (10 years ago it was employees)

The Challenge to Auditing Presented by The Internet

- Transaction flows are External
  - External copies of transactions on many Internet nodes
  - External Service Providers for accounting systems
    - require giving control to outsiders with different incentives
- Audit samples may be impossible to obtain
  - Because they require access to 3rd party databases
- Transaction flows are intermingled between companies
- Environmental, physical and logical security problems grow exponentially
  - Externally originated viruses and hacking
  - are the major source of risk
    - (10 years ago it was employees)